

MOBILE ATTACKS AND COUNTERMEASURES

Anatomy of a Mobile Attack

Because of the extensive usage and implementation of bring your own device (BYOD) policies in organizations, mobile devices have emerged as a prime target for attacks. Attackers scan these devices for vulnerabilities. Such attacks can involve the device and the network layer, the data center, or a combination of them.

The Device

Vulnerabilities in mobile devices pose significant risks to sensitive personal and corporate data. Attackers targeting the device itself can use various entry points. Device-based attacks are of the following types:

Browser-based Attacks

- **Phishing:** Phishing emails or pop-ups redirect users to fake web pages that mimic trustworthy sites, asking them to submit their personal information. Mobile users are more likely to be victims of phishing sites because the devices are small in size and they display only short URLs, limited warning messages, scaled-down lock icons, and so on.
- **Framing:** Involves a web page integrated into another web page using the iFrame elements of HTML. An attacker exploits iFrame functionality used in the target website, embeds his/her malicious web page, and uses clickjacking to steal users' sensitive information.
- **Clickjacking:** also known as a **user interface redress attack**, is a malicious technique used to trick web users into clicking something different from what they think they are clicking.
- **Man-in-the-Mobile:** An attacker implants malicious code into the victim's mobile device to bypass password verification systems that send one-time passwords (OTPs) via SMS or voice calls. Thereafter, the malware relays the gathered information to the attacker.
- **Buffer Overflow:** An abnormality whereby a program, while writing data to a buffer, surfeits the intended limit and overwrites the adjacent memory. This results in erratic program behavior, including memory access errors, incorrect results, and mobile device crashes.
- **Data Caching:** Data caches in mobile devices store information that is often required by these devices to interact with web applications, thereby preserving scarce resources and resulting in better response time for client applications. Attackers attempt to exploit these data caches to access the sensitive information stored in them.

Phone/SMS-based Attacks

- **Baseband Attacks:** Attackers exploit vulnerabilities in a phone's GSM/3GPP baseband processor, which sends and receives radio signals to cell towers.
- **SMiShing:** A phishing fraud in which an attacker uses SMS to send text messages containing deceptive links to malicious websites or telephone numbers to a victim. The attacker tricks the victim into clicking the link or calling the phone number and revealing his or her personal information.

Application-based Attacks

- **Sensitive Data Storage:** Some apps installed and used by mobile users employ weak security in their database architecture, which makes them targets for attackers who seek to hack and steal the sensitive user information stored in them.
- **No Encryption/Weak Encryption:** Apps that transmit unencrypted or weakly encrypted data are susceptible to attacks such as session hijacking.
- **Improper SSL Validation:** Security loopholes in an application's SSL validation process may allow attackers to circumvent the data security.

- **Configuration Manipulation:** Apps may use external configuration files and libraries that can be exploited in a configuration manipulation attack. This includes gaining unauthorized access to administration interfaces and configuration stores, as well as the retrieval of clear-text configuration data.
- **Dynamic Runtime Injection:** Attackers manipulate and abuse the run time of an application to circumvent security locks and logic checks, access privileged parts of an app, and even steal data stored in memory.
- **Unintended Permissions:** Misconfigured apps can sometimes open doors to attackers by providing unintended permissions.
- **Escalated Privileges:** Attackers engage in privilege escalation attacks, which take advantage of design flaws, programming errors, bugs, or configuration oversights to gain access to resources that are usually protected from an application or user.

The System

- **No Passcode/Weak Passcode:** Many users choose not to set a passcode or use a weak PIN, passcode, or pattern lock, which an attacker can easily guess or crack to compromise sensitive data stored in the mobile device.
- **iOS Jailbreaking:** The process of removing the security mechanisms set by Apple to prevent malicious code from running on the device. It provides root access to the OS and removes sandbox restrictions. Thus, jailbreaking involves many security risks as well as other risks to iOS devices, including poor performance, malware infection, and so on.
- **Android Rooting:** Rooting allows Android users to attain privileged control (known as “root access”) within Android’s subsystem. Like jailbreaking, rooting can result in the exposure of sensitive data stored in the mobile device.
- **OS Data Caching:** An OS cache stores used data/information in memory temporarily on the hard disk. An attacker can dump this memory by rebooting the victim’s device with a malicious OS and extract sensitive data from the dumped memory.
- **Passwords and Data Accessible:** iOS devices store encrypted passwords and data using cryptographic algorithms that have certain known vulnerabilities. Attackers exploit these vulnerabilities to decrypt the device’s Keychain, exposing user passwords, encryption keys, and other private data.
- **Carrier-loaded Software:** Pre-installed software or apps on devices may contain vulnerabilities that an attacker can exploit to perform malicious activities such as deleting, modifying, or stealing data on the device, eavesdropping on calls, and so on.
- **User-initiated Code:** User-initiated code is an activity that tricks the victim into installing malicious applications or clicking links that allow an attacker to install malicious code to exploit the user’s browser, cookies, and security permissions.

The Network

- **Wi-Fi (weak encryption/no encryption):** Some applications fail to encrypt data or use weak algorithms to encrypt data for transmission across wireless networks. An attacker may intercept the data by eavesdropping on the wireless connection. Although many applications use SSL/TLS, which offers protection for data in transit, attacks against these algorithms can expose users’ sensitive information.
- **Rogue Access Points:** Attackers install an illicit wireless access point by physical means, which allows them to access a protected network by hijacking the connections of legitimate network users.
- **Packet Sniffing:** An attacker uses sniffing tools such as Wireshark and Capsa Network Analyzer to capture and analyze all the data packets in network traffic, which generally include sensitive data such as login credentials sent in clear text.

- **Man-in-the-Middle (MITM):** Attackers eavesdrop on existing network connections between two systems, intrude into these connections, and then read or modify the data or insert fraudulent data into the intercepted communication.
- **Session Hijacking:** Attackers steal valid session IDs and use them to gain unauthorized access to user and network information.
- **DNS Poisoning:** Attackers exploit network DNS servers, resulting in the substitution of false IP addresses at the DNS level. Thus, website users are directed to another website of the attacker's choice.
- **SSLStrip:** A type of MITM attack in which attackers exploit vulnerabilities in the SSL/TLS implementation on websites. It relies on the user validating the presence of the HTTPS connection. The attack invisibly downgrades connections to HTTP without encryption, which is difficult for users to detect in mobile browsers.
- **Fake SSL Certificates:** Fake SSL certificates represent another type of MITM attack in which an attacker issues a fake SSL certificate to intercept traffic on a supposedly secure HTTPS connection.

The Data Center / CLOUD

Data centers have two primary points of entry: a **web server** and a **database**.

Web-server-based Attacks

- **Platform Vulnerabilities:** Attackers exploit vulnerabilities in the OS, server software (e.g., IIS), or application modules running on the web server. They may monitor communication between a mobile device and the web server to expose protocol or access control flaws.
- **Server Misconfiguration:** A misconfigured server may allow attackers to gain unauthorized access to resources.
- **Cross-site Scripting (XSS):** Exploits vulnerabilities in dynamically generated web pages, allowing attackers to inject malicious client-side code (JavaScript, VBScript, ActiveX, HTML, or Flash) into legitimate websites.
- **Cross-Site Request Forgery (CSRF):** Tricks an authenticated user's browser into sending unauthorized requests to a trusted site, compromising the session integrity.
- **Weak Input Validation:** Attackers forge communications or bypass application logic to exploit missing validation checks. This can lead to XSS, buffer overflow, injection attacks, and system malfunction.
- **Brute-Force Attacks:** Attackers use trial-and-error to guess valid input fields (e.g., passwords). Systems that allow unlimited attempts are highly vulnerable.

Other examples include cross-origin resource sharing exploits, side-channel attacks, hypervisor attacks, and VPN-targeted exploits.

Database Attacks

- **SQL Injection:** Attackers use non-validated input to inject SQL commands through a web application for execution by the backend database, granting unauthorized access or retrieving information directly.
- **Privilege Escalation:** Exploits to gain high-level database access, allowing attackers to steal sensitive data.
- **Data Dumping:** Forces the database to dump data, revealing sensitive records.
- **OS Command Execution:** Attackers inject OS-level commands into database queries, potentially gaining root-level access to the host system.

Mobile Platform Attack Vectors and Vulnerabilities

Mobile Attack Vectors

Mobile devices have attracted the attention of attackers owing to their widespread use. Such devices access many of the resources that traditional computers use. Moreover, these devices have some unique features that have led to the emergence of new attack vectors and protocols. Such vectors make mobile phone platforms susceptible to malicious attacks both from the network and upon physical compromise.

Given below are some of the attack vectors that allow an attacker to exploit vulnerabilities in mobile OS, device firmware, or mobile apps:

Malware	Data Exfiltration	Data Tampering	Data Loss
Virus and rootkit	Extracted from data streams and email	Modification by another application	Application vulnerabilities
Application modification	Print screen and screen scraping	Undetected tamper attempts	Unapproved physical access
OS modification	Copy to USB key and loss of backup	Jailbroken device	Loss of device

Mobile Platform Vulnerabilities and Risks

As smartphones surpass PCs as the preferred devices for accessing the Internet, managing communications, and more, attackers are increasingly drawn to mobile research and implementing possible attack schemes against mobile platforms to compromise users' security and privacy, or even gain complete control over the victims' devices.

- Malicious Apps in Stores
- Mobile Malware
- App Sandboxing Vulnerabilities
- Weak Device and App Encryption
- OS and App Update Issues
- Jailbreaking and Rooting
- Mobile Application Vulnerabilities
- Privacy Issues (Geolocation)
- Weak Data Security
- Excessive Permissions
- Weak Communication Security
- Physical Attacks

OWASP Top 10 Mobile Risks

According to OWASP (Open Worldwide Application Security Project), the following are the top 10 mobile risks:

- **M1 — Improper Platform Usage**
This category covers the misuse of a platform feature or the failure to use platform security controls. It includes Android intents, platform permissions, and the misuse of Touch ID, Keychain, or some other security control that is part of the mobile device's OS. There are several ways in which mobile apps can be exposed to this risk.

- **M2 — Insecure Data Storage**

Insecure data storage vulnerability arises when development teams assume that users and malware will not have access to a mobile device's file system and subsequently to sensitive information in the device's data stores. "Jailbreaking" or rooting a mobile device bypasses encryption protection mechanisms. OWASP recommends analyzing platforms' data security application programming interfaces (APIs) and calling them appropriately.

Unintended data leakage occurs when a developer unintentionally places sensitive data in a location on the mobile device that is easily accessible by other apps on the device. Such leakage is normally caused by vulnerabilities in the OS, frameworks, compiler environment, new hardware, and so on, without a developer's knowledge. It is a significant threat to the OS, platforms, and frameworks; thus, it is important to understand how they handle features such as URL caching, browser cookie objects, and HTML5 data storage.

- **M3 — Insecure Communication**

This category covers poor handshaking, incorrect SSL versions, weak negotiation, cleartext communication of sensitive assets, and so on. Such flaws expose an individual user's data and can lead to account theft. If the adversary intercepts an admin account, the entire site could be exposed. A poor Secure Socket Layer (SSL) setup can also facilitate phishing and man-in-the-middle (MITM) attacks.

- **M4 — Insecure Authentication**

This category captures notions of authenticating the end user or bad session management, such as:

- Failing to identify the user when it is required
- Failure to maintain the user's identity when it is required
- Weaknesses in session management

- **M5 — Insufficient Cryptography**

The code applies cryptography to a sensitive information asset. However, cryptography is insufficient in some ways. This category covers issues in which cryptography is attempted but not performed correctly. This vulnerability will result in the unauthorized retrieval of sensitive information from the mobile device. To exploit this weakness, an adversary must successfully convert encrypted code or sensitive data into its original unencrypted form due to weak encryption algorithms or flaws in the process of encryption.

- **M6 — Insecure Authorization**

This category captures failures in authorization (e.g., authorization decisions on the client side and forced browsing). It is distinct from authentication issues (e.g., device enrolment and user identification).

When an app does not authenticate users at all in a situation where it should (e.g., granting anonymous access to some resource or service when authenticated and authorized access is required), then it is an authentication failure and not an authorization failure.

- **M7 — Client Code Quality**

This category covers "Security Decisions via Untrusted Inputs" and is one of the less frequently used categories. It is the catch-all for code-level implementation problems in the mobile client, which are distinct from server-side coding mistakes. It captures buffer overflows, format string vulnerabilities, and various other code-level mistakes where the solution is to rewrite some code that is running on

the mobile device. Most exploitations that fall into this category result in foreign code execution or DoS on remote server endpoints (and not the mobile device itself).

- **M8 — Code Tampering**

This category covers binary patching, local resource modification, method hooking, method swizzling, and dynamic memory modification.

Once an application is delivered to a mobile device, its code and data resources are resident on the device. An attacker can directly modify the code, change the memory contents dynamically, change or replace the system APIs that the application uses, or modify the application's data and resources. Thus, the attacker can directly subvert the intended use of the software for personal or monetary gain.

- **M9 — Reverse Engineering**

This category includes the analysis of the final core binary to determine its source code, libraries, algorithms, and other assets. Software such as IDA Pro, Hopper, otool, and other binary inspection tools give the attacker insights into the inner workings of the application. Thus, he/she may exploit other nascent vulnerabilities in the application and uncover information about backend servers, cryptographic constants and ciphers, and intellectual property.

- **M10 — Extraneous Functionality**

Often, developers include hidden backdoor functionality or other internal development security controls that are not intended to be released into a production environment. For example, a developer may accidentally include a password as a comment in a hybrid app. Another example involves the disabling of two-factor authentication during testing.

Typically, an attacker seeks to understand extraneous functionality within a mobile app to discover hidden functionality in the backend systems. Attackers will typically exploit such extraneous functionality directly from their own systems without any involvement by the end users.

Mobile Security Guidelines and Security Tools

General Guidelines for Mobile Platform Security

Given below are various guidelines that help you to protect your mobile device:

- Do not load too many applications, and avoid auto-upload of photos to social networks
- Perform a security assessment of the application architecture
- Maintain configuration control and management
- Install applications from trusted application stores
- Securely wipe or delete the data when disposing of the device
- Do not share the information within GPS-enabled apps unless it is necessary
- Never connect two separate networks, such as Wi-Fi and Bluetooth, simultaneously
- Disable wireless access, such as Wi-Fi and Bluetooth, if not in use
- Ensure that your Bluetooth is "off" by default. Turn it on whenever it is necessary
- Disable wireless access, such as Wi-Fi and Bluetooth, if not in use, to avoid illegal wireless access to the device
- Disable sharing/tethering Internet connections over Wi-Fi and Bluetooth when not in use
- **Use Passcode**
 - Configure a strong passcode with the maximum possible length to gain access to your mobile devices
 - Set an idle timeout to automatically lock the phone when not in use

- Enable the lockout/wipe feature after a certain number of attempts
 - Consider an eight-character complex passcode
 - Thwart passcode guessing: set erase data to ON
- **Update OS and Apps**
 - Update OS and apps to keep them secure
 - Apply software updates when new releases are available
 - Perform regular software maintenance
- **Enable Remote Management**
 - In an enterprise environment, use MDM software to secure, monitor, manage, and support mobile devices deployed across the organization
- **Do not allow Rooting or Jailbreaking**
 - Ensure that your MDM solutions prevent or detect rooting/jailbreaking
 - Include this clause in your mobile security policy
- **Use Remote Wipe Services**
 - Use remote wipe services such as Find My Device (Android) and Find My iPhone or FindMyPhone (Apple iOS) to locate your device should it be lost or stolen
 - Report a lost or stolen device to IT so that they can disable certificates and other access methods associated with the device
- **Encrypt Storage**
 - If supported, configure your mobile device to encrypt its storage with hardware encryption
 - Use device encryption and patch applications
 - Encrypt the device and backups
- **Perform periodic backup and synchronization**
 - Use a secure, over-the-air backup-and-restore tool that performs periodic background synchronization
 - (Android) Back up to your Google account so that sensitive enterprise data is not backed up to the cloud
 - Control the location of backups
 - Encrypt backups
 - Keep sensitive data off shared mobile devices. If enterprise information is locally stored on a device, then it is recommended that this device not be openly shared
 - Limit logging data stored on the device
 - Use a secure data-transfer utility or encrypt data in transit to or from the device, to ensure confidentiality and data integrity

Mobile Security Tools

- **Malwarebytes Security:** An antimalware mobile tool that provides protection against malware, ransomware, and other growing threats to Android devices. It blocks, detects, and removes adware and malware; conducts privacy audits for all apps; and ensures safer browsing.
- **Lookout Personal:** A mobile security app that offers protection against malware, phishing, and device theft, along with backup and system monitoring features.
- **Zimperium's zIPS:** An enterprise-grade mobile threat defense solution that detects and prevents advanced mobile attacks in real time.

- **BullGuard Mobile Security:** A mobile protection tool providing antivirus, antitheft, and backup features for Android devices.
- **Norton Security for iOS:** A mobile security app that safeguards iOS devices from phishing, unsafe Wi-Fi networks, and online threats.
- **Comodo Mobile Security:** A comprehensive mobile security solution offering antivirus protection, privacy protection, and real-time threat detection.

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.